Türkiye perakende dijital banka backend özeti

Bu belge, banking_backend reposunda nelerin yapıldığını ve nasıl yapıldığını açıklar. Proje lisanslı bir banka ürünü değildir; mimariyi, servis sınırlarını ve iş kurallarını proje sahibi kurdu, kodu Cursor yazdı. Amaç: Clean Architecture, CQRS, kuyruk ve çift kayıt ledger öğrenmek.

1. Ne inşa edildi

On bağımsız .NET 9 servisi, her biri kendi PostgreSQL veritabanı ile, artı YARP gateway. Servisler birbirinin DB'sine yazmaz. Senkron HTTP servisler arası yok. Haberleşme MassTransit + RabbitMQ ve EF outbox/inbox. Gateway yalnızca istemci kenarıdır.

- AuthService (5229) - kayıt, login, refresh rotation, e-posta OTP, 2FA
- CustomerService (5029) - CIF, KYC belge, kyc:review onayı
- AccountService (5039) - KYC sonrası vadesiz TRY + TR IBAN (ISO 7064 mod-97)
- LedgerService (5049) - bakiye, hold, çift kayıt journal, ekstre, kart hold/capture, kredi posting, döviz çift journal
- PaymentService (5059) - virman, test kredisi, giden/gelen FAST ve EFT, döviz çevrimi, açık bankacılık PIS virman
- NotificationService (5069) - müşteri bildirim kutusu
- CardService (5079) - sanal debit (token + last4, PAN yok), authorize/capture/reverse
- RiskService (5089) - işlem sonrası izleme (dört kural), ödemeyi durdurmaz
- LoanService (5099) - faizsiz taksit, ops loans:review onay, Ledger kullandırım/ödeme
- OpenBankingService (5109) - rıza + AIS hesap listesi + PIS virman (PSD2/OAuth2 değil)
- Gateway (5000) - YARP path öneki; JWT doğrulamaz

2. Nasıl çalıştık (sıra ve yöntem)

İş sırası başta onaylandı: Auth -> Customer KYC -> Account -> birim testler -> Ledger -> Payment virman -> test kredisi + FAST -> EFT -> gelen FAST -> gelen EFT -> bildirim -> ekstre -> kart -> risk izleme -> kredi -> YARP gateway -> döviz (USD/EUR) -> açık bankacılık (rıza + AIS + PIS virman). Her dilimde aynı kalıp kopyalandı:

- Sözleşme önce: Banking.Contracts içine event kaydı (örneğin TransferRequested).
- Payment/Card HTTP handler kaydı açar, status Initiated, event'i outbox ile yayınlar, SaveAsync.
- Ledger consumer MediatR komutunu çalıştırır. InvalidOperationException iş reddidir: matching Rejected event + SaveAsync.
- Ledger posting tek DB işleminde: hold varsa yaz, journal debit=credit, hold release veya tut, completed event, SaveAsync.
- Payment/Card completed/rejected/held consumer durumu günceller; Completed üzerine yazılmaz.
- Idempotency: aynı HTTP Idempotency-Key mevcut kaydı döner; Ledger'da aynı journal key ikinci posting yazmaz, completed event yeniden yayınlanır.

Birim testler xUnit + bellek içi UnitOfWork. HTTP ve RabbitMQ yok. Kural testte kilitlenir: örnek hold available'ı düşürür ledger'ı düşürmez; Completed overwrite edilmez.

3. Mimari kurallar

- Katmanlar: Domain (entity/enum) / Application (MediatR, DTO, repository arayüzü) / Infrastructure (EF, JWT, MassTransit) / Presentation (API).
- JWT her serviste aynı JwtSettings. Claim: customer_id. Operasyon yetkileri permission claim: kyc:review, customers:read, roles:assign, payments:credit, payments:settle, risk:review, loans:review.
- Hesap KYC onayı olmadan açılmaz. Bakiye Account tablosunda tutulmaz; Ledger sorumluluğudur.
- Müşteri hesabı yükümlülük (liability): ledger = credit - debit. Available = ledger - aktif hold.
- InternalClearingTry sistem hesabı giden FAST/EFT/kart tahsil ve gelen FAST/EFT/test kredisi karşılığıdır.

- Dahili IBAN'a giden FAST/EFT reddedilir (virman kullan). Gelen işlemde hedef dahili IBAN olmalı; kaynak dahili ise virman.

4. Auth, Customer, Account

Auth

Kayıt local biter ve UserRegistered outbox ile çıkar (şifre, token, OTP event'te yok). Login OTP ve 2FA, refresh token ailesi, grace dışı reuse 401 ve family revoke. Diğer servisler Auth'a HTTP atmaz; aynı JWT anahtarı ile token doğrular.

Customer

UserRegistered CIF iskeleti açar (Prospect, TCKN yok). Aynı CustomerId ikinci kayıt açmaz. POST /api/customers TCKN/adres/KVKK doldurur. KYC belge + submit. Review kyc:review ister. Onay KycApproved yayınlar.

Account

Hesap HTTP POST ile açılmaz. KycApproved consumer (CustomerId, DemandDeposit, TRY) yoksa Active vadesiz TRY ve 26 karakter TR IBAN yazar, AccountOpened yayınlar. Ledger, Payment ve Card bu event'i kendi projeksiyonları için dinler.

5. Ledger: para nasıl kaydedilir

AccountOpened ile müşteri vadesiz projeksiyonu 0 bakiye ile açılır. Açılış kredisi yoktur. Available için ops test kredisi, gelen FAST/EFT veya kredi kullandırım gerekir. Journal satırında debit toplamı credit toplamına eşit olmalıdır.

Journal / hold anahtarları:

```
transfer:{id}          virman (hold transfer-hold:{id}, post sonrası release)
test-credit:{id}       debit clearing / credit müşteri
fast:{id}              hold fast-hold:{id}, sonra debit kaynak / credit clearing
incoming-fast:{id}     debit clearing / credit müşteri, hold yok
eft:{id}               hold eft-hold:{id} settle'a kadar; iade journal yok
incoming-eft:{id}      hold incoming-eft-hold:{id} clearing üzerinde
card-auth:{id}         hold card-auth-hold:{id}; capture debit müşteri / credit clearing
loan:{id}              debit clearing / credit müşteri (kullandırım)
loan-repay:{id}        debit müşteri / credit clearing (taksit; id = installmentId)
fx-sell:{id}           debit kaynak / credit kaynak clearing
fx-buy:{id}            debit hedef clearing / credit hedef
```

Ekstre: GET /api/ledger/accounts/{accountId}/statement?from=&to= from öncesi satırlar opening ledger, dönem satırları hareket, to dahil closing ledger. Hold ekstrede yoktur; ekstre kayıtlı journal'dır. Okuma customer_id veya customers:read.

6. Payment: ödeme kaydı ve limit

Payment bakiye tutmaz. AccountOpened projeksiyonu + ödeme satırları tutar. Create event yayınlar (Initiated). Ledger sonucu Completed / Rejected / Held getirir. OpenBankingPaymentRequested aynı virmanı açar; Transfer.Id = InitiationId, idempotency open-banking:{id}.

- Virman: kaynak çağırana ait, aktif, aynı para birimi. Hold + debit kaynak / credit hedef.
- Test kredisi: payments:credit, max 100_000, clearing debit / müşteri credit.
- Giden FAST: dış TR IBAN, hemen post. Giden EFT: hold, ops payments:settle ile settle veya iade.
- Gelen FAST: payments:credit, dahili hedef IBAN, hold yok. Gelen EFT: clearing hold, ops settle/iade.

Limit: işlem başına 50_000. UTC gününde giden virman+FAST+EFT toplam 100_000 (Initiated+Held+Completed; Rejected hariç). Gelen FAST/EFT bu havuza sayılmaz. Idempotency-Key başlık zorunlu; aynı anahtar mevcut kaydı döner.

7. Gelen EFT neden FAST'ten farklı

Giden EFT'de hold müşteri hesabındadır; available düşer, ledger aynı kalır, takas gelince debit kaynak / credit clearing. Gelen EFT tersidir ama müşteri available'ı beklemede artmamalı ve azalmamalıdır. Bu yüzden hold InternalClearingTry üzerine yazılır (incoming-eft-hold:{id}). Müşteri satırı yok. Settle event'i DestinationAccountId taşır çünkü clearing hold hedefi hatırlamaz. Settle: debit clearing / credit müşteri (incoming-eft:{id}). İade: clearing hold release, journal yok.

8. Bildirim nasıl bağlandı

TransferCompleted gibi event'lerde CustomerId yok. NotificationService Payment DB'sine bakamaz ve HTTP atamaz. Çözüm: Payment (ve Card) durum gerçekten değiştiğinde NotificationRequested yayınlar (CustomerId, Type, Title, Body, SourceId). Publish, SaveAsync'ten önce çağrılır ki outbox aynı transaction'da kalsın. NotificationService ayrıca KycApproved ve AccountOpened dinler. Unique (Type, SourceId) ikinci bildirimi engeller. GET /api/notifications/me, POST /api/notifications/{id}/read (yalnız sahip). SMS/e-posta gönderilmez; bu bir inbox servisidir.

9. Kart: sanal debit, PCI değil

AccountOpened CardService'te bir sanal debit açar (hesap başına bir). PAN yok: Token Guid N format (32 hex), Last4 dört hane, Brand Virtual. Authorize, EFT hold kalıbıdır: available kontrol, card-auth-hold:{id}, CardAuthorizationHeld. Capture, EFT settle kalıbıdır: debit müşteri / credit clearing, hold release. Reverse hold'u bırakır, journal yok. Dondurma POST /api/cards/{id}/freeze. Limit authorize başına 50_000 TRY. Bu sahte POS'tur; 3DS ve gerçek kart processor yok.

10. Testler (bu dilimde)

- OpenBankingService.UnitTests: rıza Active ve 32 hex token; aynı Idempotency-Key mevcut kaydı döner; bilinmeyen TPP ve sahip olunmayan hesap reddeder; AIS rızalı hesapları listeler; iptal/süresi dolmuş/PIS-only AIS reddeder; PIS OpenBankingPaymentRequested yayınlar; TransferCompleted Completed üzerine yazmaz.
- PaymentService.UnitTests: OpenBanking PIS initiation id = transfer id, idempotency open-banking:{id}.

Auth/Customer/Account/Ledger/Notification/Card/Risk/Loan testleri önceki dilimlerde aynı kalıpta duruyor.

11. Risk izleme (MASAK değil)

RiskService işlem sonrası taramadır. Transfer/FAST/EFT/gelen/kart/FX/kredi requested event'lerini dinler, posting'i durdurmaz. CustomerId event'te olmadığı için AccountOpened projeksiyonu kullanılır. KycApproved ad ve TCKN taşır; CustomerProfile yazılır. Tutar ≥ 25_000 LargeAmount; UTC günü giden toplam ≥ 80_000 DailyVelocity; UTC günü 20_000-25_000 altı 3 işlem Structuring; sahte izleme listesi WatchlistHit. Ops risk:review ile GET /api/risk/alerts ve close. Bu bir MASAK motoru değildir.

12. Kredi (lisanslı ürün değil)

LoanService sade tüketici kredisidir: faiz yok, eşit anapara taksiti, vade 3-12 ay, tavan 100_000 TRY. POST /api/loans JWT sahip ve Idempotency-Key ister; durum Applied kalır, posting yok. Ops POST /api/loans/{id}/approve (loans:review) LoanDisbursementRequested yayınlar. Ledger debit InternalClearingTry / credit müşteri (loan:{id}), LoanDisbursementPosted. LoanService N taksit yazar; son satır kalanı alır. POST /api/loans/{id}/repay sıradaki Pending taksiti öder: LoanRepaymentRequested, debit müşteri / credit clearing (loan-repay:{installmentId}). Pending kalmayınca Completed. Applied iken ops red: POST /api/loans/{id}/reject. Okuma GET /api/loans/me ve GET /api/loans/{id} (sahip veya customers:read).

13. Gateway (YARP)

Services/Gateway http://localhost:5000. Path önekleri ilgili servis portuna gider (/api/auth, /api/customers, /api/accounts, /api/ledger, /api/payments, /api/notifications, /api/cards, /api/risk, /api/loans, /api/open-banking). Gateway JWT

doğrulamaz; Authorization, Idempotency-Key ve X-Consent-Token ileri gider. Bu üretim ingress değildir.

14. Döviz (piyasa değil)

TRY vadesiz KYC ile açılır. POST /api/accounts USD veya EUR ikinci vadesiz açar (CustomerId, DemandDeposit, Currency tekil). Aynı döviz tekrar mevcut kaydı döner. POST /api/payments/fx-conversions çağıranın kendi hesapları arasında çevirir. Kur sabittir: 1 USD = 34 TRY, 1 EUR = 37 TRY. TCMB yayını yoktur. Ledger iki journal yazar: fx-sell kaynak para biriminde, fx-buy hedef para biriminde (InternalClearingUsd / InternalClearingEur). Aynı para birimi virmana gider. Günlük 100_000 havuzu TRY karşılığını sayar. Risk TryEquivalent ile tarar.

15. Açık bankacılık (PSD2 değil)

OpenBankingService lisanslı PSD2 ve OAuth2 değildir. Müşteri POST /api/open-banking/consents (JWT, Idempotency-Key) ile TPP sandbox-tpp'ye AIS (1) ve/veya PIS (2) verir (1-90 gün, sahip hesaplar). Token Guid N (32 hex). TPP X-Consent-Token gönderir; AIS JWT istemez. GET /api/open-banking/ais/accounts yalnızca IBAN/döviz döner (Ledger HTTP yok, canlı bakiye yok). POST /api/open-banking/pis/payments OpenBankingPaymentRequested yayınlar. Payment virman açar: Transfer.Id = InitiationId, idempotency open-banking:{id}. TransferCompleted / TransferRejected / OpenBankingPaymentRejected initiation durumunu günceller. İptal POST /api/open-banking/consents/{id}/revoke. Okuma GET /api/open-banking/consents/me ve GET /api/open-banking/pis/payments/{id}.

16. Bilinçli olarak yapılmayanlar

Öğrenme diliminin dışında bırakılanlar lisanslı banka işidir.

- PCI kart processor ve 3DS - PAN saklanmaz; token sahte kimliktir.
- Gerçek MASAK / AML kural motoru - RiskService dört kuraldır (LargeAmount, DailyVelocity, Structuring, WatchlistHit)
- Yatırım
- PII log maskeleme ürün katmanı
- Gerçek FAST/EFT takas ağı, gerçek döviz piyasası ve lisanslı PSD2/OAuth2

17. Nasıl çalıştırılır

PostgreSQL localhost:5432 ve RabbitMQ localhost:5672 ayakta olsun. Her servis kendi migration'ını uygular, Presentation projesinden koşar. Gateway'in veritabanı yoktur.

```
dotnet ef database update --project Services/AuthService/src/AuthService.Infrastructure --startup-project Services/AuthService/src/AuthService.Presentation
... aynı komut Customer, Account, Ledger, Payment, Notification, Card, Risk, Loan, OpenBanking için ...
dotnet run --project Services/Gateway
dotnet test
```

Bağlantı dizeleri appsettings.json içindedir; üretim sırrı değildir. İnceleme için Swagger her Presentation'da Development'ta açıktır (JWT Bearer).

18. Bu dilimde eklenenlerin özeti

- Sözleşmeler: OpenBankingPaymentRequested / OpenBankingPaymentRejected.
- OpenBankingService 5109, BankingOpenBankingServiceDb, rıza + AIS liste + PIS virman.
- Payment PIS: Transfer.Id = InitiationId, idempotency open-banking:{id}.
- Gateway /api/open-banking -> 5109; X-Consent-Token ileri gider.
- 13 OpenBanking birim testi; Payment initiation id = transfer id.

Commit/push bu belgede yapılmadı; yalnızca istendiğinde yapılır.